

Security Scan Report

Target: <https://pentest-ground.com:9000>

Scan Date: August 26, 2026 at 18:02 UTC

Scan ID: fea35944-5c83-4941-9d9f-02f140ee29fd

0 CRITICAL

0 HIGH

4 MEDIUM

3 LOW

Executive Summary

Security scan of 'https://pentest-ground.com:9000' identified 12 raw findings, reduced to 7 unique issues after deduplication. 4 MEDIUM-priority issue(s) should be addressed in the current development sprint. 3 LOW-priority issue(s) have been logged for backlog tracking.

Scan Statistics

Metric	Value
Total Raw Findings	12
After Deduplication	7
Critical Findings	0
High Findings	0
Medium Findings	4
Low Findings	3
Scan Duration	55.7s

Detailed Findings

[MEDIUM] #1: Api Missing Auth in openapi.json:0

Risk Score	0.4988
Affected Location	https://pentest-ground.com:9000/openapi.json:0
Vulnerability Type	API_MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in openapi.json. OpenAPI advertises 9 operation(s) without a security requirement.

Code or HTTP Excerpt

```
1 | Unauthenticated operations: GET /, GET /eval, GET /help, POST /search, POST /tokens, GET /uptime/{fla
```

Business Impact

This vulnerability could be exploited to compromise authentication tokens.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[MEDIUM] #2: Api Missing Auth in openapi.yaml:0

Risk Score	0.4988
Affected Location	https://pentest-ground.com:9000/openapi.yaml:0
Vulnerability Type	API_MISSING_AUTH
CWE ID	CWE-306
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in openapi.yaml. OpenAPI advertises 9 operation(s) without a security requirement.

Code or HTTP Excerpt

```
1 | Unauthenticated operations: GET /, GET /eval, GET /help, POST /search, POST /tokens, GET /uptime/{fla
```

Business Impact

This vulnerability could be exploited to compromise authentication tokens.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[MEDIUM] #3: Api Security Misconfiguration in openapi.json:0

Risk Score	0.4230
Affected Location	https://pentest-ground.com:9000/openapi.json:0
Vulnerability Type	API_SECURITY_MISCONFIGURATION
CWE ID	CWE-693
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in openapi.json. OpenAPI defines state-changing operations but no global security scheme.

Code or HTTP Excerpt

```
1 | State-changing operations: POST /search, POST /tokens, POST /user, POST /widget
```

Business Impact

This vulnerability could be exploited to compromise authentication tokens.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[MEDIUM] #4: Api Security Misconfiguration in openapi.yaml:0

Risk Score	0.4230
Affected Location	https://pentest-ground.com:9000/openapi.yaml:0
Vulnerability Type	API_SECURITY_MISCONFIGURATION
CWE ID	CWE-693
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in openapi.yaml. OpenAPI defines state-changing operations but no global security scheme.

Code or HTTP Excerpt

```
1 | State-changing operations: POST /search, POST /tokens, POST /user, POST /widget
```

Business Impact

This vulnerability could be exploited to compromise authentication tokens.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[LOW] #5: Clickjacking in pentest-ground.com:9000:0

Risk Score	0.3589
Affected Location	https://pentest-ground.com:9000:0
Vulnerability Type	CLICKJACKING
CWE ID	CWE-1021
Detected By	url-scanner

Explanation

The page can be embedded in an iframe, allowing attackers to overlay invisible controls and trick users into clicking. Found in pentest-ground.com:9000. Missing X-Frame-Options header.

Code or HTTP Excerpt

```
1 | Response headers: X-Frame-Options = (not set)
```

Business Impact

Users could be tricked into performing unintended actions on your application such as changing settings or transferring funds.

Fix Recommendation

Best Fix: Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors 'self'.

[LOW] #6: Reconnaissance Surface in pentest-ground.com:9000:0

Risk Score	0.3500
Affected Location	https://pentest-ground.com:9000:0
Vulnerability Type	RECONNAISSANCE_SURFACE
CWE ID	CWE-200
Detected By	url-scanner

Explanation

A security vulnerability was detected in your code. Found in pentest-ground.com:9000. Passive reconnaissance inventory of the reachable page.

Code or HTTP Excerpt

```
1 | Title: Vulnerable REST API
2 | Status: 200
3 | Content-Type: text/html; charset=utf-8
4 | Technologies disclosed: nginx/1.31.4
5 | Same-page links: 4
6 | Forms: 0
7 | Scripts: 6
```

Business Impact

This vulnerability could be exploited to compromise application security.

Fix Recommendation

Best Fix: Review the flagged code and apply security best practices. Consult the OWASP guidelines for the relevant vulnerability type.

[LOW] #7: Missing Security Header in pentest-ground.com:9000:0

Risk Score	0.3168
Affected Location	https://pentest-ground.com:9000:0
Vulnerability Type	MISSING_SECURITY_HEADER
CWE ID	CWE-319
Detected By	url-scanner

Explanation

The server response is missing recommended HTTP security headers that instruct browsers to enable built-in protections. Found in pentest-ground.com:9000. Missing HTTP Strict-Transport-Security (HSTS) header.

Code or HTTP Excerpt

```
1 | Response headers: Strict-Transport-Security = (not set)
```

Business Impact

Without this header, user accounts and personal data is more vulnerable to XSS, clickjacking, or MIME-type confusion attacks.

Fix Recommendation

Best Fix: Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS connections and prevent SSL stripping.

Appendix

Deduplication Statistics

Total raw findings: 12 | After deduplication: 7 | Reduction: 42%

Scan Metadata

Scan ID	fea35944-5c83-4941-9d9f-02f140ee29fd
Target	https://pentest-ground.com:9000
Timestamp	2026-08-26T18:02:20.876591+00:00
Duration	55.7s
Scanners Used	url-scanner
Scanner Versions	url-scanner=builtin-1.0

Raw Findings Data (JSON)

```
[
  {
    "id": "6620510b-74d8-48c6-a463-7de61f1d1dd6",
    "title": "Api Missing Auth in openapi.json:0",
    "file": "https://pentest-ground.com:9000/openapi.json",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "API_MISSING_AUTH",
    "description": "OpenAPI advertises 9 operation(s) without a security requirement. Verify these endpoints",
    "rule_id": "openapi-operation-missing-security",
    "confidence": 0.75,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "Unauthenticated operations: GET /, GET /eval, GET /help, POST /search, POST /tokens, GET /",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.4988,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "A security vulnerability was detected in your code. Found in openapi.json. OpenAPI a",
    "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin",
    "business_impact": "This vulnerability could be exploited to compromise authentication tokens.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea",
    "raw": {
      "spec_url": "https://pentest-ground.com:9000/openapi.json",
      "operations": [
        "GET /",
        "GET /eval",
        "GET /help",
        "POST /search",
        "POST /tokens",
        "GET /uptime/{flag}",
        "POST /user",
        "GET /user/{user}",
        "POST /widget"
```

```

    ]
  },
  {
    "id": "07c2c5eb-3d0f-4c2d-ba18-748a823d6fbf",
    "title": "Api Missing Auth in openapi.yaml:0",
    "file": "https://pentest-ground.com:9000/openapi.yaml",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "API_MISSING_AUTH",
    "description": "OpenAPI advertises 9 operation(s) without a security requirement. Verify these endpoints",
    "rule_id": "openapi-operation-missing-security",
    "confidence": 0.75,
    "cwe_id": "CWE-306",
    "cvss_score": null,
    "code_snippet": "Unauthenticated operations: GET /, GET /eval, GET /help, POST /search, POST /tokens, GET /",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.4988,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "A security vulnerability was detected in your code. Found in openapi.yaml. OpenAPI a",
    "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin",
    "business_impact": "This vulnerability could be exploited to compromise authentication tokens.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea",
    "raw": {
      "spec_url": "https://pentest-ground.com:9000/openapi.yaml",
      "operations": [
        "GET /",
        "GET /eval",
        "GET /help",
        "POST /search",
        "POST /tokens",
        "GET /uptime/{flag}",
        "POST /user",
        "GET /user/{user}",
        "POST /widget"
      ]
    }
  },
  {
    "id": "234ae14c-cbaa-46f9-8e23-9e7e837d6599",
    "title": "Api Security Misconfiguration in openapi.json:0",
    "file": "https://pentest-ground.com:9000/openapi.json",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "API_SECURITY_MISCONFIGURATION",
    "description": "OpenAPI defines state-changing operations but no global security scheme. Confirm authent",
    "rule_id": "openapi-no-global-security",
    "confidence": 0.7,
    "cwe_id": "CWE-693",
    "cvss_score": null,
    "code_snippet": "State-changing operations: POST /search, POST /tokens, POST /user, POST /widget",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.423,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "A security vulnerability was detected in your code. Found in openapi.json. OpenAPI o",
    "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin",
    "business_impact": "This vulnerability could be exploited to compromise authentication tokens.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea",
    "raw": {

```

```

    "spec_url": "https://pentest-ground.com:9000/openapi.json",
    "operations": [
      "POST /search",
      "POST /tokens",
      "POST /user",
      "POST /widget"
    ]
  },
  {
    "id": "2da957d5-4333-42e3-b436-65384ad94af7",
    "title": "Api Security Misconfiguration in openapi.yaml:0",
    "file": "https://pentest-ground.com:9000/openapi.yaml",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "API_SECURITY_MISCONFIGURATION",
    "description": "OpenAPI defines state-changing operations but no global security scheme. Confirm authentication.",
    "rule_id": "openapi-no-global-security",
    "confidence": 0.7,
    "cwe_id": "CWE-693",
    "cvss_score": null,
    "code_snippet": "State-changing operations: POST /search, POST /tokens, POST /user, POST /widget",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.423,
    "risk_category": "MEDIUM",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "A security vulnerability was detected in your code. Found in openapi.yaml. OpenAPI defines state-changing operations but no global security scheme. Confirm authentication.",
    "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelines for API security.",
    "business_impact": "This vulnerability could be exploited to compromise authentication tokens.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes read-only data.",
    "raw": {
      "spec_url": "https://pentest-ground.com:9000/openapi.yaml",
      "operations": [
        "POST /search",
        "POST /tokens",
        "POST /user",
        "POST /widget"
      ]
    }
  },
  {
    "id": "09e17f88-6e1f-467e-8c7a-12f62b8a87b8",
    "title": "Clickjacking in pentest-ground.com:9000:0",
    "file": "https://pentest-ground.com:9000",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "CLICKJACKING",
    "description": "Missing X-Frame-Options header. The site may be vulnerable to clickjacking attacks where a malicious site can trick users into performing actions on your application.",
    "rule_id": "header-missing-x-frame-options",
    "confidence": 0.85,
    "cwe_id": "CWE-1021",
    "cvss_score": null,
    "code_snippet": "Response headers: X-Frame-Options = (not set)",
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.3589,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "The page can be embedded in an iframe, allowing attackers to overlay invisible content and trick users into performing actions on your application.",
    "fix_suggestion": "Add X-Frame-Options: DENY header or use Content-Security-Policy with frame-ancestors.",
    "business_impact": "Users could be tricked into performing unintended actions on your application such as logging in or changing their password.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes read-only data."
  }
]

```

```

    "raw": {
      "url": "https://pentest-ground.com:9000",
      "header": "X-Frame-Options",
      "check": "missing_header"
    }
  },
  {
    "id": "967a3371-ad1f-4382-bb16-75d823bc540d",
    "title": "Reconnaissance Surface in pentest-ground.com:9000:0",
    "file": "https://pentest-ground.com:9000",
    "line_start": 0,
    "line_end": null,
    "severity": "LOW",
    "vuln_type": "RECONNAISSANCE_SURFACE",
    "description": "Passive reconnaissance inventory of the reachable page. Use the listed endpoints, forms,
    "rule_id": "recon-page-surface",
    "confidence": 1.0,
    "cwe_id": "CWE-200",
    "cvss_score": null,
    "code_snippet": "Title: Vulnerable REST API\nStatus: 200\nContent-Type: text/html; charset=utf-8\nTechno
    "sources": [
      "url-scanner"
    ],
    "risk_score": 0.35,
    "risk_category": "LOW",
    "category_source": "score",
    "category_reason": "score-threshold",
    "llm_explanation": "A security vulnerability was detected in your code. Found in pentest-ground.com:9000:0",
    "fix_suggestion": "Review the flagged code and apply security best practices. Consult the OWASP guidelin
    "business_impact": "This vulnerability could be exploited to compromise application security.",
    "attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",
    "next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea
    "raw": {
      "url": "https://pentest-ground.com:9000",
      "surface": {
        "title": "Vulnerable REST API",
        "links": [
          "https://github.com/jorritfolmer/vulnerable-api",
          "https://pentest-ground.com:9000/help",
          "https://pentest-ground.com:9000/openapi.yaml",
          "https://pentest-tools.com"
        ],
        "scripts": [
          "https://cdn.jsdelivr.net/npm/alpinejs@3.13.0/dist/cdn.min.js",
          "https://cdn.tailwindcss.com",
          "https://cdn.usefathom.com/script.js",
          "https://pentest-ground.com/alpine-data.js",
          "https://unpkg.com/@popperjs/core@2",
          "https://unpkg.com/tippy.js@6"
        ],
        "forms": []
      },
      "technologies": [
        "nginx/1.31.4"
      ]
    }
  },
  {
    "id": "d91b9b37-2c86-4b91-8a72-c315bb6fcff4",
    "title": "Missing Security Header in pentest-ground.com:9000:0",
    "file": "https://pentest-ground.com:9000",
    "line_start": 0,
    "line_end": null,
    "severity": "MEDIUM",
    "vuln_type": "MISSING_SECURITY_HEADER",
    "description": "Missing HTTP Strict-Transport-Security (HSTS) header. Without HSTS, browsers may allow c
    "rule_id": "header-missing-strict-transport-security",
    "confidence": 0.95,
    "cwe_id": "CWE-319",
    "cvss_score": null,
    "code_snippet": "Response headers: Strict-Transport-Security = (not set)",

```

```
"sources": [  
  "url-scanner"  
],  
"risk_score": 0.3168,  
"risk_category": "LOW",  
"category_source": "score",  
"category_reason": "score-threshold",  
"llm_explanation": "The server response is missing recommended HTTP security headers that instruct brows  
"fix_suggestion": "Add Strict-Transport-Security: max-age=31536000; includeSubDomains to force HTTPS con  
"business_impact": "Without this header, user accounts and personal data is more vulnerable to XSS, cli  
"attack_path": "UNKNOWN: deterministic fallback has no runtime proof.",  
"next_test": "Run one authorized, read-only validation test and stop if it changes state or exposes rea  
"raw": {  
  "url": "https://pentest-ground.com:9000",  
  "header": "Strict-Transport-Security",  
  "check": "missing_header"  
}  
}  
]
```